Table 2.2 Recommended CSP directives for REST responses

Directive	Value	Purpose
`default-src`	`'none'`	Prevents the response from loading any scripts or resources.
`frame-ancestors`	`'none'`	A replacement for `X-Frame-Options`, this prevents the response being loaded into an iframe.
`sandbox`	n/a	Disables scripts and other potentially dangerous content from being executed.

2.6.3 Implementing the protections

You should now update the API to implement these protections. You'll add some filters that run before and after each request to enforce the recommended security settings.

First, add a `before()` filter that runs before each request and checks that any POST body submitted to the API has a correct Content-Type header of `application/json`. The Natter API only accepts input from POST requests, but if your API handles other request methods that may contain a body (such as PUT or PATCH requests), then you should also enforce this filter for those methods. If the content type is incorrect, then you should return a 415 Unsupported Media Type status, as this is the standard status code for this case. You should also explicitly indicate the UTF-8 character-encoding in the response, to avoid tricks for stealing JSON data by specifying a different encoding such as UTF-16BE (see https://portswigger.net/blog/json-hijacking-for-the-modern-web for details).